[EWB courses - AI powered cybersecurity]

Assessment 01: Security foundation

Student Details:

- Name: SAURAV THAKUR
- Batch / group: [cybersecurity batch 1]
- course: AI powered cybersecurity (EWB)
- Submission Date: [2/11/2026]

AI use declaration

- Declaration: AI assistance was used for drafting, structuring and clasifying ~~technical~~ technical concepts. All final answers, log triages and technical justification were independently reviewed and verified against course material and reference framework.

TASK A | Secure a Student account – 25 Marks

Q A1. Identify five distinct risks. For each, name the asset at risk and explain how confidentiality, integrity or availability could be affected. (10 Marks)

Ans→

Risk	Asset at risk	CIA impact & Explanation
(a.) Reused short password	Email and learning portal Accounts	Confidentiality & integrity: A short, reused password makes account vulnerable to brute force or credential stuffing attacks. If an attacker cracks the password on one service, they gain unauthorized read and write access to sensitive academic records and communications.

(b)

Risk	Assest at risk	CIA impact & explanation
(b) Approving unexpected MFA prompts	Student Account & active portal session	Blindly tapping "Approve" on multi-factor authentication prompt leads to MFA fatigue exploitation, this allows an attacker posing as a legitimate user to bypass security control and compromise account confidentiality.
(c) postponed system updates	Laptop 'os' & Local Application	confidentiality, integrity & Availability: Ignoring security updates leaves know software vulnerabilities unpatched, Malware or attackers can exploit these gaps to compromise system confidentiality.
(d) single copy project work	Academic Files & Local project Storage	Availability: Storing the only copy of an assignment on a single laptop risks complete data loss, if hard ~~wate~~ drives fails or get corrupted.
(e) Unattended Shared Access on Laptop	Saved Browser Credentials & local Document	confidentiality & integrity: → Allowing a friend to use the laptop while logged into Mary's personal account permit unauthorized physical acces. This risks accidental deletion, modification or exposure of private academic data.

TASK 'A' | Secure a student account (10 Marks)

A_2. Give one practical control for each risk. Explain why it helps, including at least one limitation. prioritise your first three actions and justify the order

Ans: practical controls & Limitation table

Risk	practical control	why it helps	Limitation
• Reused Short password	Use a password Manager to generate and ~~store~~ store a strong unique passphrase.	Eliminates password reuse across platform and protects against credential stuffing or brute force cracks	If the master password is forgotten or compromised, access to the entire vault is lost.
• Approving unexpected MFA promts	Enable Number Matching MFA or context-Aware authentication	forces the user to Match numbers shown on the login screen preventing blind fatigue approval	Requires compatible devices/ applications and slightly increases user friction during signin.
• postponed System updates	Turn on automatic System and security updates	patches known software vulnerabilities automatically before attackers can exploit them.	updates can sometimes trigger unexpected reboot or disrupt active tasks.

Action prioritisation & justification

1. First priority : Strong password & Number Matching MFA
   - Justification : This directly stops active credential compromise and blocks ongoing ~~or~~ unauthorized remote access attempts on account.
2. Second priority : 3 2 1 backups!
   Justification → Safeguards unique academic work against permanent loss due to potential hardware failure or Malware.
3. Third priority : Automatic updates & Screen locking!
   Justification → provides continuous baseline system security and blocks local or physical tampering.

Q3. Explain authentication versus authorisation using Mira's learning portal as your example. (5 marks)

Ans: Authentication (who you are):

- concept: the process of verifying the identity of a user or system.
- Mira's portal example: when Mira opens her learning portal and enters her username along with her password (and approves her MFA prompt), the system verifies her credential to confirm that she is indeed Mira,

Authorisation (what you are allowed to do):

- concept: The process of granting or denying specific access rights and permission to an authenicated user based on their role.
- Mira portal example: Once Mira is successfully authenticated, the portal checks her student role permission, it authorizes her to view her course materials.

TASK B : Analyse a suspicious Message (25 Marks)

Q B1 Identify five specific warning sign from the evidence. Quote only the relevant phrase and explain why it needs scrutiny (10 marks)

Ans.

1. Quoted evidence: "award @ campus-awards. example"

Scrutiny

Domain Mismatch:

The official campus domain is campus.example. The sender is using an untrusted external look-alike domain (designed to deceive the recipient).

2. "Reply-To: help @ personal-Awards. example

Inconsistent Reply to Header

The reply address routes response to an entirely separate third party domain (personal-awards.example) rather than the official sender or institution.

3. "final warning - scholarship expires in 20 Minutes

Artificial urgency & fear Tactics:

Attackers creates extreme time pressure and threaten negative consequences to panic the victim into acting without verifying the facts.

B2. Describe a safe verification process using an independently obtained official contact or portal. Explain why HTTPS or a familiar display name alone would not prove the message is genuine (5 marks).

Ans Safe Verification process

1. (i) Out of Band channel: Open a web browser independently (without clicking any links in the suspicious message) and navigate to the known official campus domain or call the college administration office using a pre-verified phone number.

(ii) Direct confirmation: Enquire directly with official support staff or check your student account portal dashboard to confirm if any genuine scholarship action or notices are pending.

2. Why HTTPS and Display Names Do Not prove Authenticity

- HTTPS Limitation: HTTPS only guarantees that the data transmission b/w your browser and that specific website is encrypted. Attackers routinely acquire free SSL/TLS certificates for malicious phishing domains to make them look secure.

- Display Name Limitation: A display name (eg "scholarship desk") is a customizable text field that any sender can easily forge or spoof to impersonate a trusted entity without any technical verification.

B3. Write a short response plan for a student who already entered a password and OTP. Include immediate containment, official reporting and follow-up checks. Do not ask the student to send you the password or OTP (7 marks).

Ans 1. Immediate containment:

- Access the official portal immediately from a secure device and change your college account password
- Terminate all active login sessions and sign out from all registered devices to cut off the attacker's access.

2. Official Reporting

- Report the credential exposure immediately to the official campus IT helpdesk or security team via phone or their verified support email channel.

3. Follow up Security checks

- Inspect your account sign-in logs, inbox forwarding rules, registered recovery emails and multifactor authentication methods to ensure no unauthorized changes were made.
- If the same password was reused on other personal account (such as email or banking), update those.

B4. State one important facts you cannot establish from this message alone and what additional evidence would help (3 marks)

Ans- • Unestablished Fact: Whether the email is Not genuinely sent from an external attacker or if the sender domain is actively spoofed and whether SPF, DKIM, or DMARC authentication checks passed or failed.

• Additional Evidence Needed: The complete raw email headers (included ~~Received~~: routing path, and sender IP metrics) to analyse the true origin of the messages.

[TASK 'C' : Triage a sign in alert]

Q. C1. Build a four point timeline connecting the logs and uses statement. Distinguish observed events from your interpretation (8 marks).

Ans 1. 09:00 – 09:01 IST (Observed & Interpreted):

- observed: Student07 Successfully authenticated with a password and approved and MFA prompt from the trusted classroom IP address 192.0.2.10,

interpretation: This present normal, authorized Morning login activity by the Student.

2. 10:14 – 10:16 IST (Observed & interpreted):

- observed: Two failed password attempt followed by a successful password entry from external IP address (198.51.100.23)

interpretation: An external entity or automated tool brute-forced or used compromised credentials to successfully enter the password.

3. 10:17 – 10:18 IST (Observed & interpreted):

- observed: An MFA request was initially denied at 10:17, followed by an MFA approval at 10:18 from IP 198.51.100.23

interpretion: Matches the uses statement (i did'n sign after 9:05, at Around 10:18 approved) Indication MFA fatigue attack.

4. 10:20 IST (Observed & interpreted)

- observed: A new session was Successfully created for Student07 from IP 198.51.100.23

- Interpretion: The unauthorized actor succesfully completed the Sign-in Sequence and established an active session on Student account.

Q2. Give a likely explanation and one alternative explanation. List two additional checks that could distinguish them. Avoid claiming the source IP uniquely identifies a person (7 marks)

Ans- Likely Explanation: An unauthorized actor obtained Student 07 password and initiated login attempt from IP 198.51.100.23. When blocked from multi factor authentication, the attacker flooded the user with repeated push Notification until the Student approved the prompt out of annoyance.

- Alternative Explanation: (Legitimate user off campus)

Student 07 left the classroom, switched to a mobile data network or VPN (resulting in IP 198.51.100.23), mistyped their password twice, mistakenly hit "Deny" on the first push notification, and subsequently approved the legitimate push.

Two additional checks to Distinguish explanation

→ Review the user Agent string and device fingerprint logged during the 09:00 classroom session versus the 10:20 session to see if a completely different hardware device or OS was used.

→ Analyse subsequent network activity and telemetry associated with session 10:20 to check if Abnormal data access or unauthorized file download occurred.

C3. Recommend three prioritised response action for the authorised IT team. Include preservation of evidence and protection of the account (6 marks).

Ans- First priority : Revoke session & Reset credentials

- immediately terminate active session and reset password

second priority : preserve Authentication & access logs

- securely export and archive all authentication logs.

Third priority : Upgrade security configuration

- Enforce Number Matching MFA to prevent future MFA fatigue bypass and review account recovery setting.

C4. Write a 60-100 word Incident summary : evidence, uncertainty priority and next action. (4 marks).

Ans. Incident summary : on 18 Oct 2026 at 10:20 IST, an unauthorized session was successfully created for user student07 from external IP 198.51.100.23. Following repeated failed password and an approved MFA push, the user confirms they did not sign in after 09:05 and approved the prompt out of annoyance.

Uncertainity : The true identity and physical location of the actor behind IP 198.51.100.23 remain unconfirmed.

Priority High : due to active unauthorized session access

Next action : Immediately revoke active session, force user credential reset and preserve all access logs for forensic review.

TASK D : Review an AI Security Answer

Q. D1. Identify and correct five unsafe or unsupported claims/actions in this output. Explain each correction using the evidence or a trustworthy reference. (10 marks),

Ans →

	Unsafe AI claims / Action	Correction & Technical Justification
1.	"The email is safe because it was HTTPS."	Incorrect: HTTPS only encrypts the transit channel and a web server; it does not verify the trustworthiness of the sender or the legitimacy of the website content. Phishing domains routinely obtain valid SSL/TLS certificates.
2.	"The sign-in logs prove that the person using 198.51.100.23 stole the password."	Unsupported: logs record IP addresses and network events, not human identity. An IP address can represent a corporate proxy, a shared Wi-Fi, a VPN or a compromised proxy rather than specific individual.
3.	"MFA prevents every account compromise".	False: Multi-factor authentication significantly raises security barriers but can still be bypassed through MFA fatigue attacks.
4.	"Delete the suspicious logs".	Dangerous Action: Deleting logs destroy critical forensic evidence required for security incident tracking.

Q2. Write a better prompt asking an AI tool to analyse only the synthetic evidence, separate facts from assumption, avoid requesting secrets and state uncertainty. Do not include real student data. (5 Marks).

Ans "You are a cyber security assistant. Analyse the provided synthetic log data and message evidence. Rely strictly on factual details present in text; clearly separate observed facts from analytical assumption. Do not ask for generate or accept actual user password, secret keys or personally identifiable information; state any uncertainties and limitation explicitly. Provide your analysis in concise bullet points.

Q4. Add a short AI use declaration and two evidence/reference notes supporting your reasoning (4 marks).

Ans AI use declaration:

Declaration: AI tools (Gemini) were used solely for structural formating guidance, defining draft, clarity and self-evaluating promt logic. All technical risk analyses, factual interpretations, and security advice were authored, verified and finalized independently.